Semana 16 — Conteúdo de 2 aulas

Computação em Nuvem e Virtualização

Ricardo Pasquati Pontarolli

Técnico em Redes de Computadores · IFSP Boituva · pasquati@ifsp.edu.br · v44

Semana 16 — Conteúdo de 2 aulas

- **Aula 25:** Segurança em Nuvem: Soluções e Boas Práticas
- **Aula 26:** Atividade: Segurança em Nuvem

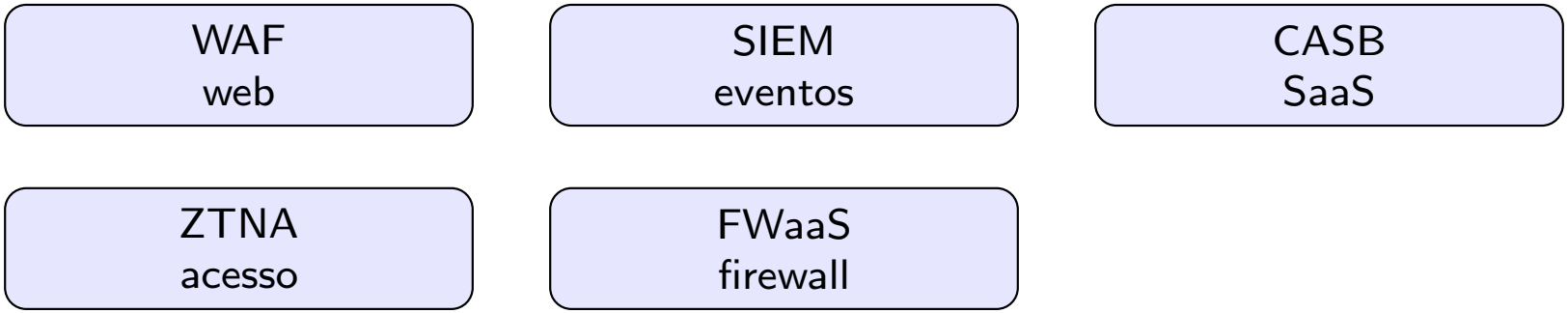
Aula 25 — Segurança em Nuvem: Soluções e Boas Práticas

Objetivos da Aula

- Conhecer as principais **soluções de segurança** em nuvem.
- Entender siglas: **WAF, SIEM, CASB, ZTNA, FWaaS**.
- Compreender o conceito de **Zero Trust**.
- Consolidar **boas práticas** de segurança.

Panorama de Soluções

- **WAF** — protege aplicações web.
- **SIEM** — correlação de eventos de segurança.
- **CASB** — controle de acesso a serviços de nuvem.
- **ZTNA** — acesso de rede baseado em identidade.
- **FWaaS** — firewall como serviço.



WAF — Web Application Firewall

- Filtra e monitora o tráfego **HTTP/HTTPS**.
- Protege contra **SQL Injection, XSS, bots**.
- Pode operar na borda (**CDN**) ou junto à aplicação.
- Exemplos: AWS WAF, Cloudflare.

SIEM

- **Security Information and Event Management**.
- Coleta e **correlaciona logs** de várias fontes.
- Detecta **padrões suspeitos** e gera alertas.
- Essencial para monitoramento e resposta a incidentes.

CASB e ZTNA

- **CASB:** intermedeia e audita o acesso a SaaS; aplica políticas (**DLP**).
- **ZTNA:** acesso "zero trust" — valida identidade e contexto **a cada acesso**.
- Reduz a exposição da rede e substitui VPNs tradicionais.
- Alinhados ao modelo **Zero Trust**.

FWaaS

- **Firewall as a Service:** firewall entregue pela nuvem.
- Aplica regras de **camada de rede e aplicação**.
- Escalável e gerenciado centralmente.
- Integra-se a políticas de **microssegmentação**.

Zero Trust

- Princípio: **“nunca confie, sempre verifique”**.
- Não assume que a rede interna é segura.
- **Verificação contínua** de identidade e dispositivo.
- **Menor privilégio** e microssegmentação.

Boas Práticas Consolidadas

- MFA e IAM bem configurado.
- Criptografia em trânsito e em repouso.
- **Monitoramento** contínuo (SIEM) e alertas.
- **Backups** e testes de restauração.
- **Atualizações** e gestão de vulnerabilidades.

Resposta a Incidentes

- **Preparação:** planos e ferramentas prontos.
- **Detecção:** monitoramento e alertas.
- **Contenção:** isolar o incidente.
- **Erradicação e recuperação**.
- **Lições aprendidas** após o incidente.

> **Note**
>
> A segurança em nuvem é **contínua**: não basta configurar uma vez; é preciso monitorar, atualizar e revisar sempre.

Resumo da Aula

- **WAF, SIEM, CASB, ZTNA e FWaaS** cobrem camadas distintas.
- **Zero Trust** muda o paradigma do perímetro de rede.
- Boas práticas incluem MFA, criptografia e monitoramento.
- Resposta a incidentes é **cíclica** e planejada.

Atividade Rápida

- Associe cada sigla (WAF, SIEM, CASB, ZTNA) à sua função.
- Explique o princípio **Zero Trust**.
- Liste três **boas práticas** de segurança em nuvem.

Referências

- NIST — *Zero Trust Architecture*.
- CSA — *Security Guidance*.
- Documentação dos provedores de nuvem.

Aula 26 — Atividade: Segurança em Nuvem

Objetivos da Aula

- Consolidar os conceitos de **segurança em nuvem**.
- Aplicar o **modelo de responsabilidade compartilhada**.
- Praticar a análise de **riscos e controles**.
- Preparar para a avaliação do bimestre.

Revisão Rápida

- **CID:** confidencialidade, integridade, disponibilidade.
- **Responsabilidade compartilhada** (cliente $\times$ provedor).
- **IAM, MFA, menor privilégio, criptografia**.
- **WAF, SIEM, CASB, ZTNA, FWaaS** e **Zero Trust**.

Estudo de Caso

*Uma startup hospeda uma aplicação web na nuvem. Um bucket de armazenamento foi deixado **público** e vazou dados de clientes.*

- Quais **falhas** ocorreram?
- De **quem** era a responsabilidade?
- Que **controles** evitariam o incidente?

Roteiro da Atividade

- Grupos de **3 a 4 alunos**.
- Analise o caso sob a ótica de **CID** e responsabilidade compartilhada.
- Proponha **controles** técnicos e de processo.
- Apresente uma **lista de recomendações**.
- Registre no **Moodle**.

Parte 1 — Diagnóstico

- Identifique a **vulnerabilidade** central (configuração incorreta).
- Aponte o impacto em **CID**.
- Quem deveria proteger o **bucket**? (cliente ou provedor?)

Parte 2 — Controles Propostos

- **Técnicos:** IAM, criptografia, monitoramento, WAF.
- **Processo:** revisão de configurações, políticas, treinamento.
- **Monitoramento:** SIEM e alertas.
- **Governança:** auditoria e conformidade.

Parte 3 — Apresentação

- Apresente o **plano de resposta** ao incidente.
- Ordem de prioridade dos **controles**.
- Tempo: ~**5 minutos** por grupo.
- Discussão com a turma.

Critérios de Avaliação

- **Adequação** dos controles propostos.
- Domínio do **modelo de responsabilidade compartilhada**.
- **Clareza** e organização da apresentação.
- **Participação** no grupo.

! Important

A **Avaliação 2 (GIFT, 10 questões)** cobre segurança, gerenciamento e contêineres. Revise antes de responder.

Checklist do Grupo

- ☐ Vulnerabilidade identificada.
- ☐ Impacto em CID analisado.
- ☐ Responsabilidades definidas.
- ☐ Controles técnicos e de processo listados.
- ☐ Apresentação pronta.

Resumo da Aula

- Aplicamos segurança em um **caso real**.
- Reforçamos a **responsabilidade compartilhada**.
- Praticamos **análise de risco** e resposta a incidentes.
- Próxima aula: **modelos de gerenciamento em nuvem**.

Referências

- NIST — *Cloud Security*.
- CSA — *Cloud Controls Matrix*.
- Material das aulas 28 a 30.